CO2 – ASSIGNMENT 2

ETHICAL HACKING

Course Code	ITA1439	**Course Name**	Ethical Hacking
Assignment Title	Evaluation and Engineering of Footprinting, Re connaissance and Social-Engineering-Awareness Workflows in an Authorized Assessment		
Student Name	A GUNA SEKAR	**Register Number**	192525302
Slot	b	**Total Marks**	50

CO2: Execute footprinting and social-engineering techniques such as DNS analysis, competitive intelligence gathering and attack simulations to collect information for identifying potential security risks.

Submission note: This report uses a controlled, illustrative lab dataset and documented commands. No live organization or real individual was targeted. Values shown as sample observations are not claimed to be live tool output. Replace them with captured outputs from your instructor-approved lab if actual execution evidence is required.

Methodology and Scope

The assessment follows the sequence **Understand → Predict → Design → Collect → Analyse → Evaluate → Defend → Validate**. All examples remain within authorized scope. The reserved example domains used in the scenarios are placeholders for teaching; the DNS outputs and measurements below are constructed test observations, not claims about current public DNS.

Scope rules: Only the explicitly listed domain and its approved subdomains are in scope. Third-party SaaS providers are recorded as dependencies, not scanned. Personal data is excluded. Unverified search results are marked for confirmation rather than treated as facts.

Evidence convention: "Predicted" means the expected result before the test; "observed (lab model)" means the result assigned in the controlled test case for analysis. Commands are provided so the same workflow can be repeated against a domain owned by the student or explicitly authorized by the instructor.

Q1 – Evaluate and Engineer a Footprinting Strategy (8 Marks)

1. Strategy design and technique classification

The strategy combines multiple sources because WHOIS, DNS, search engines and archived pages expose different parts of an organization's public footprint. Collection begins with passive sources, then uses only low-impact active DNS queries against approved nameservers.

Technique	Type	Purpose / evidence	Reliability checks
WHOIS / RDAP lookup	Passive	Registrar, registration dates, nameservers and status.	Check lookup date and registrar/RDAP source; privacy masking is not evidence of missing infrastructure.
Search operators	Passive	Public pages, indexed files and exposed technical references.	Verify page ownership, date and context; snippets can be stale.
Archived pages	Passive	Historical pages and retired service references.	Treat as historical leads, not current configuration.
dig / nslookup DNS queries	Active	A, MX, NS and TXT records from DNS resolvers.	Record resolver, query time, TTL and authoritative answer.
Approved zone-transfer test	Active	Checks whether an authorized authoritative server permits AXFR.	Attempt only with written permission; a refused transfer is not proof that all DNS is secure.

2. Collection procedure and commands

For an authorized domain such as **corp.example** in a private lab, preserve the exact command, timestamp, resolver and output. Example command sequence:

```
whois corp.example
dig corp.example A
dig corp.example MX
dig corp.example NS
dig corp.example TXT
nslookup -type=MX corp.example
dig @<authorized-nameserver> corp.example AXFR
```

The AXFR command is executed only when the domain owner has explicitly authorized it. The command is shown as a test procedure, not as an instruction to probe unrelated domains.

3. Four contrasting test targets: prediction versus observation

Test target	Prediction before collection	Illustrative lab observation	Evaluation
T1 – Well protected	WHOIS privacy; limited indexed files; DNS records only for public services; AXFR refused.	Masked registrant; A/MX/NS/TXT present; AXFR refused; no sensitive public documents found.	Low exposure. Public service records remain useful and should be verified.
T2 – Information leak	Public documents may reveal technology, staff roles or internal naming conventions.	An old PDF names a mail platform and department structure; DNS shows mail and web hosts.	Moderate exposure. Confirm document date and remove unnecessary metadata.
T3 – DNS misconfiguration	Unexpected records or permissive transfer may reveal hostnames.	Lab nameserver permits AXFR and returns several host labels.	Higher reconnaissance exposure; restrict transfer and monitor DNS configuration.
T4 – Minimal footprint	Few indexed pages; only essential DNS records.	One landing page and minimal A/NS records; no useful archived content.	Low observable footprint, but absence of results does not prove absence of assets.

4. Source conflicts and reliability

A WHOIS record can show one nameserver set while a cached DNS resolver returns an older set. Search engines may index a document that has since been removed, and an archive may show a retired service. The resolution process is to record the source and retrieval time, query authoritative DNS, compare TTLs, verify the document's publication date and classify unresolved differences as "needs confirmation." No single source is treated as definitive.

5. Changed condition: fifty subdomains and third-party services

For fifty subdomains, the original strategy remains valid in principle but needs inventory management and scope controls. Create an approved hostname list, group names by parent domain, deduplicate results, apply rate limits, and assign each third-party service a separate ownership/scope status. Do not scan a SaaS provider merely because a CNAME points to it. Run passive collection first, then query only approved DNS names. Store evidence with source, timestamp, status, confidence and scope. This reduces repeated work and prevents scope creep.

Final strategy: multi-source passive-first collection followed by narrowly scoped DNS verification, with explicit provenance and confidence labels.

Q2 – Build a Reliable DNS Footprinting Workflow (7 Marks)

1. Workflow

Input approved domain → confirm scope → query A, MX, NS and TXT → record resolver and TTL → compare recursive and authoritative answers → identify delegation and split-horizon differences → perform AXFR only if expressly authorized → validate anomalies → report exposure and remediation.

```
dig lab.example A
dig lab.example MX
dig lab.example NS
dig lab.example TXT
nslookup -type=A lab.example
```

```
nslookup -type=MX lab.example
dig @ns1.lab.example lab.example AXFR # authorized lab
only
```

2. Six contrasting DNS cases

Case	Predicted records	Illustrative observation	Meaning / action
D1 Secured authoritative DNS	A/MX/NS/TXT; AXFR denied.	Expected records returned; AXFR REFUSED.	Normal exposure; retain least-privilege DNS settings.
D2 AXFR permitted	Zone transfer may expose all zone names.	AXFR returns web, mail, vpn and dev host labels.	Information disclosure; restrict transfer to approved secondary servers.
D3 Stale record	Old address may remain visible until TTL/cache expiry.	Recursive resolver returns old A record; authoritative answer has new address.	Record TTL and resolver; re-query after expiry and correct stale zone data.
D4 Split-horizon	Internal and external answers differ.	External query returns public address; internal lab resolver returns private address.	Expected policy behaviour; document vantage point and resolver.
D5 Third-party delegation	NS/CNAME points to service provider.	Subdomain delegated to a hosted DNS provider.	Treat provider as out-of-scope unless separately authorized.
D6 TXT inconsistency	TXT may contain SPF/verification strings and can be fragmented.	Two resolvers show different TXT values due to cache/update timing.	Compare authoritative response, TTL and query time; do not infer compromise.

3. Split-horizon, delegation and caching

Split-horizon DNS deliberately serves different answers to internal and external clients, so the tester must record the network vantage point. Delegation means another authoritative provider manages a child zone; it does not grant permission to test that provider. Recursive resolvers cache answers according to TTL, so two queries can differ temporarily. Record query time, resolver, authoritative server and TTL before deciding that a record is inconsistent.

4. Zone-transfer risk and countermeasure

An unrestricted AXFR can disclose a large list of hostnames and service roles, improving an attacker's map of the organization. It does not itself grant access, but it reduces uncertainty and can expose forgotten systems. The countermeasure is to allow transfers only to explicitly configured secondary DNS servers, use TSIG authentication where supported, monitor transfer requests and review zone contents. After remediation, repeat the authorized test: the expected outcome is AXFR refused for unapproved clients and successful transfer only for approved secondaries.

Conclusion: DNS findings must be interpreted in context. A record is not automatically current, externally visible or in scope simply because one resolver returned it.

Q3 – Create a Competitive-Intelligence Awareness Utility (7 Marks)

1. Modular workflow architecture

Source selection → documented search → item extraction → provenance capture → confidence/freshness

check → map item to social-engineering scenario → assign human-risk level → recommend awareness control → produce report. The utility is an awareness and risk-assessment tool; it does not contact or deceive real people.

2. Public sources and search operators

Source	Example operator / documented step	Possible item	Technique and warning indicator
Job advertisements	site:careers.example.org "IT support"	Technology names, role titles, reporting structure.	Pretexting/phishing: message uses a real role or tool; verify requests through known channels.
Annual reports	site:example.org filetype:pdf annual report	Office locations, vendors, business units.	Vishing/pretexting: caller cites public business facts; verify caller identity independently.
Press releases	site:example.org intitle:press release	New projects, partnerships and launch dates.	Phishing: urgent project-themed link; inspect sender and destination.
Public professional profiles	site:linkedin.com/in "Example Corp"	Public job roles and professional relationships.	Pretexting: unexpected requests using a known colleague's name; confirm directly.
Office/location pages	site:example.org locations	Public reception and office information.	Tailgating awareness: an unknown visitor asks to follow staff through a secure door.

3. Test organizations and predictions

Org A – Rich footprint: many current job ads, reports and press releases. Prediction: high quantity of contextual information and moderate-to-high human-risk exposure. **Org B – Sparse footprint:** one basic website and few public documents. Prediction: low information volume and low-to-moderate risk. **Org C – Misleading footprint:** old reports and outdated staff profiles. Prediction: apparently rich information but low confidence; risk rises if employees or assessors fail to check freshness.

Illustrative observation: Org A produced the most usable context, Org B produced few items, and Org C produced several items that failed freshness checks. The result supports the prediction that volume alone is not a measure of reliability.

4. Item-to-technique mapping and risk evaluation

A job advertisement naming a help-desk platform could support a believable pretext; the warning indicator is an unexpected request to reset credentials or install a tool. An annual report naming a supplier could support a supplier-themed phishing lure; the warning indicator is an unusual attachment or payment change. A public office address could support a tailgating scenario; the warning indicator is an unknown person requesting entry without presenting valid access credentials. A public employee role could support vishing; the warning indicator is pressure to disclose confidential information or bypass normal verification.

The most dangerous source is not universally one category. In this illustrative test, current job advertisements and staff-role information are the most actionable when combined, because they provide current terminology and plausible pretexts. Public information becomes risky when employees trust familiarity instead of verifying the request.

5. Add two sources and countermeasures

Additional sources: public procurement notices and public conference presentations. Both can reveal vendor names, project terminology and schedules; capture only organization-level facts and exclude personal contact details.

Countermeasures: (1) teach employees to verify sensitive requests using a known, independently obtained channel; (2) enforce visitor sign-in, badge checks and anti-tailgating procedures. Also train staff to inspect sender domains, links and unexpected urgency. These controls reduce the usefulness of public information

without requiring the organization to hide all legitimate public communications.

Q4 – Design a Reconnaissance Data-Validation Mechanism (6 Marks)

1. Validation rules and decision states

Each collected item contains: item ID, value, source, retrieval time, target/domain, scope status, TTL or publication date where relevant, and confidence. The validator returns one of three states: **PASS** (in-scope, sufficiently fresh, unique and supported); **RECHECK** (potentially useful but stale, conflicting or weakly supported); or **REJECT** (out-of-scope, unverifiable or prohibited personal data).

Recommended check order: scope first → prohibited/personal-data filter → basic format → duplicate detection → freshness → source reliability → final confidence. Scope-first prevents spending time validating data that cannot be used.

2. Five test sequences and predicted outcomes

Sequence	Input condition	Prediction	Illustrative result
V1	All items in scope, current, unique, trusted source.	4 pass, 0 recheck, 0 reject.	4 PASS.
V2	One hostname belongs to an unrelated domain.	3 pass, 0 recheck, 1 reject.	Out-of-scope item REJECTED immediately.
V3	One record has an old timestamp / expired TTL.	3 pass, 1 recheck, 0 reject.	Stale record RECHECK; query authoritative source again.
V4	Same DNS record appears twice from repeated collection.	3 unique pass, 1 duplicate removed.	Duplicate marked and not counted twice.
V5	One search snippet cannot be verified at its source.	3 pass, 1 recheck or reject if source unavailable.	Unverified item held for confirmation; rejected if not recoverable.

3. Pseudocode

```
FOR each item:
```

```
IF item.target not in approved_scope: REJECT
ELSE IF item contains prohibited personal data: REJECT
ELSE IF item is duplicate: DEDUPLICATE
ELSE IF item is stale or conflicting: RECHECK
ELSE IF source cannot be verified: RECHECK
ELSE: PASS
STORE decision, reason, source and timestamp
```

4. Ordering evaluation and scale from one to fifty targets

If freshness and source checks are performed before scope validation, effort is wasted on irrelevant items. Scope-first validation rejects out-of-scope data early. Duplicate detection before expensive source verification also reduces repeated checks. The redesign therefore orders checks by low-cost/high-impact decisions first, while keeping scope rejection as the first mandatory gate.

For fifty targets, use a shared inventory, normalized hostnames, stable item IDs, deduplication keys (target + record type + value + source), and batch review queues. A human reviewer handles ambiguous scope or reliability cases. The number of collected items may grow roughly with the number of targets, but duplicate removal and early rejection prevent validation effort from growing at the same rate. Keep an audit log for

every decision.

Q5 – Evaluate Footprinting of a Hierarchical Organization (7 Marks)

1. Hierarchical representation

A sample authorized organization is represented as a tree. The root is the parent domain; child nodes are approved subdomains; terminal leaves are public services. Third-party services are labelled as dependencies and are not traversed unless separately authorized.

Tree:

corp.example

- ■■■ www.corp.example → public website (terminal)
- ■■■ mail.corp.example → mail gateway (terminal)
- ■■■ research.corp.example
- ■ ■■■ portal.research.corp.example → portal (terminal)
- ■ ■■■ archive.research.corp.example → no public data (empty leaf)
- ■■■ hr.corp.example → hosted HR service (third-party boundary)

2. Traversal and boundary condition

Use breadth-first or depth-first traversal over an approved inventory. For every node, record its parent, depth, scope status, evidence and child count. Stop expanding a node when it is outside the approved domain, is a third-party boundary, is explicitly terminal, or has no discovered children. An empty branch is recorded as "visited; no public data" rather than treated as an error.

```
QUEUE = [approved_root]
WHILE QUEUE not empty:
node = remove_front(QUEUE)
```

```
record_visit(node)
IF node not in approved_scope: mark boundary; CONTINUE
IF node is terminal: CONTINUE
children = approved_discovered_children(node)
IF children is empty: mark empty_leaf; CONTINUE
add only in-scope children to QUEUE
```

3. Test structures and prediction-versus-observation

Structure	Predicted nodes	Illustrative visits	Evaluation
Shallow: root + 3 leaves	4	4	All branches covered; low effort.
Deep: root → 3 nested levels → 2 leaves	6	6	Depth increases traversal steps and risk of missing nested names.
Irregular: root + 2 children; one child has 3 leaves; one empty branch	7 including root	7	Different branch sizes are handled; empty leaf is recorded.
Boundary: in-scope root → hosted third-party service	2 discovered; only 1 expandable	2 recorded, third party not expanded	Boundary condition prevents scope expansion.

4. Depth, branching and completeness

Depth affects the number of sequential levels to inspect; branching affects the number of nodes at each level. A wide tree can contain many nodes even when shallow, while a deep tree can require repeated expansion. A systematic traversal provides predictable coverage and an auditable record. An ad-hoc approach may be faster for a tiny footprint but can revisit nodes, miss branches and accidentally follow out-of-scope links.

Correctness check: Compare visited in-scope nodes with the approved test-tree inventory. In the four illustrative structures, all expected in-scope nodes were recorded, empty branches were closed cleanly, and the third-party node was recorded but not expanded. The boundary condition therefore meets the design objective.

Q6 – Evaluate Footprinting Approaches Under Constraints (7 Marks)

1. Approaches and outputs

Approach A – Passive OSINT: WHOIS/RDAP, search operators, public documents and archives. Output: public business context, historical references and indexed assets. It is quieter and usually creates no direct traffic to the target, but may be incomplete or stale.

Approach B – Active DNS verification: approved A/MX/NS/TXT queries and narrowly authorized DNS checks. Output: current DNS answers from a defined resolver vantage point. It is more direct and can be more current, but generates queries and still cannot reveal every hidden asset.

2. Four increasing scope sizes – illustrative measurement

Scope size	Passive steps / time	Active DNS queries / time	Interpretation

1 domain	8 steps / 4 min	4 queries / 1 min	Both practical; passive gives context, active verifies records.
5 subdomains	22 steps / 10 min	20 queries / 3 min	Active scales predictably when names are known.
20 subdomains	70 steps / 32 min	80 queries / 9 min	Passive review becomes more manual; deduplication matters.
50 subdomains	170 steps / 80 min	200 queries / 22 min	Unstructured passive review is impractical; inventory and batching required.

Note: These are constructed comparative measurements for demonstrating the evaluation method, not stopwatch results from a live engagement. Actual time depends on tools, network, resolver and analyst workflow.

3. Redundancy and engineering choice

Passive collection can repeatedly return the same indexed page, archived copy or job advertisement. Active collection can repeat the same DNS query through multiple tools or resolvers. Use canonical URLs, normalized hostnames, cache-aware query records and a collection log to reduce duplication. The faster approach is not always better: passive collection is quieter but may be stale; active DNS is more direct but exposes only the DNS view and creates target-side or resolver-side traffic.

Recommendation for small scope: combine passive OSINT with a small number of approved DNS queries; this provides context and verification without unnecessary collection. **Recommendation for large scope:** use a controlled inventory-driven DNS workflow plus prioritized passive review, deduplication and rate limits. For teaching, demonstrate both approaches on a small lab domain so students can compare their strengths and limitations. For repeated assessments, automate inventory and evidence capture while retaining

human scope review.

Q7 – Integrated Review: Diagnose, Redesign and Defend (8 Marks)

Selected workflow: Q4 reconnaissance data validation. The workflow is important because incorrect or out-of-scope findings can contaminate every later conclusion.

A. Diagnose the limitation (2 Marks)

The original validation order considered freshness and source reliability before scope and duplicate checks. This creates two bottlenecks: effort is spent validating records that should be rejected as out of scope, and repeated records may undergo the same expensive verification more than once. The root causes are poor ordering and redundant collection.

B. Establish evaluation criteria (1 Mark)

The redesign is measured using: (1) scope compliance – zero out-of-scope items accepted; (2) coverage – all valid unique in-scope items retained; (3) redundant verification count; (4) number of rechecks; and (5) total validation steps. Scope compliance and coverage take priority over speed.

C. Propose and implement redesign (2 Marks)

Redesigned order: (1) verify target against approved scope; (2) reject prohibited personal data; (3) normalize and deduplicate; (4) check freshness; (5) verify source reliability; (6) assign confidence and store evidence. The redesign uses an early scope gate and a duplicate key. Trade-off: normalization and duplicate-key maintenance add a small setup cost, and borderline duplicate records may require human review.

D. Validate and compare (2 Marks)

Metric	Original order	Redesigned order	Result
Test inputs	10 items: 6 valid unique, 2 out-of-scope, 1 stale, 1 duplicate.	Same 10 items and same scope.	Equivalent test conditions.
Out-of-scope accepted	0 after all checks	0; rejected at first gate	Both compliant; redesign rejects earlier.
Unique valid retained	6	6	Coverage unchanged.
Repeated source checks	9 checks	6 checks	3 redundant checks avoided.
Decision outcome	6 PASS, 1 RECHECK, 2 REJECT, 1 duplicate removed.	Same final outcomes.	Same accuracy with fewer repeated checks.

E. Final engineering judgment (1 Mark)

The redesign meets its objective in the constructed test: it preserves all six valid unique items, accepts no out-of-scope item, and reduces repeated source checks from nine to six. The result supports the redesigned order for routine and large-volume assessments. The original order may still be acceptable for a very small, pre-filtered dataset where scope is already guaranteed and duplicate risk is negligible. The final choice is therefore to use the redesigned workflow by default, while retaining the original only for tightly curated inputs.

Overall Conclusion

Footprinting is most reliable when multiple sources are combined and every finding is tied to its source, time, scope and confidence. DNS records must be interpreted with awareness of caching, delegation and split-horizon behaviour. Public business information can support realistic social-engineering pretexts, so awareness controls should focus on independent verification, secure visitor practices and resistance to urgency. Validation and hierarchical traversal provide the controls needed to keep reconnaissance complete, repeatable and within authorization.

Appendix – Evidence and Reproducibility Checklist

For an actual instructor-approved lab submission, attach: (1) screenshots or text exports of WHOIS/RDAP and DNS commands; (2) resolver and timestamp details; (3) raw query outputs; (4) the approved target list; (5) source URLs and retrieval dates; (6) prediction-versus-observation records; (7) validation logs; and (8) evidence that any AXFR test was explicitly authorized. The illustrative results in this report should be

replaced or supplemented with your own captured lab evidence where the instructor requires execution proof.

Formatting: Times-style serif font, 11-point body text, 1.5-style leading, black headings, structured tables and the SIMATS logo reproduced from the supplied assignment sheet.